

Unit 5 - System Security

Cryptography and Web Security (DI03016021) - GTU Diploma IT Sem 3

16% weightage | 6 hours

How to use these notes: each topic is written the way you can copy it in the exam. For a **3-mark** question write only the definition + 2-3 points. For **4 marks** add an example or table. For **7 marks** write everything, with diagram and table. Lines marked ★ show where the topic was already asked in a GTU paper (only 2 papers exist so far: Winter 2025 and Summer 2026).

Questions already asked from this unit (do these first)

- Asked in W2025 Q5(a)OR [3M: categories of intruders]
- Asked in W2025 Q5(c) [7M: define intrusion, intrusion detection, IDS; misuse and anomaly detection]
- Asked in S2026 Q5(b) [4M: role of IDS components - sensor, analyzer, user interface]
- Asked in S2026 Q5(b)OR [4M: compare NIDS and HIDS]
- Asked in W2025 Q5(b) [4M: need of firewall] (also S2026 Q5(c)OR role)
- Asked in S2026 Q5(c)OR [7M: role and characteristics of firewall]
- Asked in BOTH papers (7M each): W2025 Q5(c)OR [packet filtering, application and circuit-level gateway] + S2026 Q5(c) [working of the three firewalls]

5.1.1 Intruders and their classification

★ Asked in W2025 Q5(a)OR [3M: categories of intruders]

An **intruder** is a person or program that tries to gain unauthorised access to a system. Three classes (Anderson):

Class	Who is it?	Example
Masquerader	An outsider not authorised to use the computer, who penetrates access controls and uses a legitimate user's account	Using a stolen password to log in
Misfeasor	A legitimate user (insider) who accesses data, programs or resources he is not authorised for, or misuses his privileges	Employee reading salary files of others
Clandestine user	Someone (insider or outsider) who seizes supervisory control of the system and uses it to avoid auditing and access controls or to suppress audit collection	Admin-level hacker deleting log files

5.1.2 Intrusion, Intrusion Detection, IDS, Misuse and Anomaly detection

★ Asked in W2025 Q5(c) [7M: define intrusion, intrusion detection, IDS; misuse and anomaly detection]

- **Intrusion:** any unauthorised or malicious activity that tries to break the confidentiality, integrity or availability of a system or network.

- **Intrusion detection:** the process of **monitoring** events in a system or network and **analysing** them for signs of intrusion.
- **Intrusion Detection System (IDS):** hardware or software that does intrusion detection automatically and **raises an alarm** to the administrator.

Approaches to intrusion detection

1) Misuse detection (signature-based): the system keeps a database of **known attack patterns (signatures / rules)**. Events are compared with it; a match = alarm. *Like an antivirus.*

2) Anomaly detection (behaviour-based): the system first learns a **normal behaviour profile** of users/system (login time, files used, traffic volume). Any **significant deviation** is treated as a possible intrusion. Uses statistical methods or rule-based methods.

Point	Misuse detection	Anomaly detection
Based on	Known attack signatures	Normal behaviour profile
New (unknown) attacks	Cannot detect	Can detect
False alarms	Few	Many (false positives)
Maintenance	Signature database must be updated regularly	Profile must be retrained as behaviour changes

IDS components: sensor, analyzer, user interface

★ Asked in S2026 Q5(b) [4M: role of IDS components - sensor, analyzer, user interface]



Component	Role
Sensor	Collects data from the network or host (packets, log files, system calls) and forwards it to the analyzer. Like the eyes of the IDS.
Analyzer	Receives data from one or more sensors and decides whether an intrusion has occurred (using misuse or anomaly detection). May also suggest what action to take. Like the <i>brain</i> .
User interface	Lets the administrator view the output (alerts, reports) and control the behaviour of the IDS (set rules, thresholds). Like the <i>screen / control panel</i> .

NIDS versus HIDS

★ Asked in S2026 Q5(b)OR [4M: compare NIDS and HIDS]

Point	NIDS (Network IDS)	HIDS (Host IDS)
Placed	On the network (at switch/router, a strategic point)	On an individual computer (host)
Monitors	Network traffic / packets of the whole segment	Logs, system calls, file changes, processes of that host
Coverage	Many machines at once	Only one machine
Encrypted traffic	Cannot inspect it	Can see data after decryption on the host
Installation	One device can watch many hosts	Software must be installed on every host
Detects	Port scans, DoS, network attacks	Insider misuse, malware, file tampering
Example	Snort	OSSEC, Tripwire

5.2 Firewall - definition and need

★ Asked in W2025 Q5(b) [4M: need of firewall] (also S2026 Q5(c)OR role)

A **firewall** is a security system (hardware, software or both) placed between a **trusted internal network** and an **untrusted network (internet)** that **filters traffic** according to a security policy.



Need of firewall

1. **Blocks unauthorised access** and hackers from outside into the private network.
2. **Single control point** - all traffic passes through one place, so security policy is easy to apply and monitor.
3. **Filters traffic** by IP address, port, protocol or content; blocks malicious packets and some malware/DoS attempts.
4. **Hides internal network** (e.g. NAT) so outsiders cannot see internal IP addresses.
5. **Logging and auditing** of network activity helps to trace attacks.
6. Controls what internal users can reach (e.g. block certain websites).

5.2.1 Characteristics of Firewall

★ Asked in S2026 Q5(c)OR [7M: role and characteristics of firewall]

Characteristics (design goals)

1. **All traffic** from inside to outside and from outside to inside **must pass through the firewall** (all other access paths are blocked).
2. **Only authorised traffic**, as defined by the local security policy, is allowed to pass. Everything else is blocked.
3. The firewall itself is **immune to penetration** - it must run on a hardened, trusted system.

Techniques a firewall uses to enforce policy

- **Service control:** which services (HTTP, FTP, e-mail) can be accessed.
- **Direction control:** in which direction requests may flow.
- **User control:** which users are allowed to access which service.
- **Behaviour control:** how a service is used (e.g. filter spam).

Role in system security

- Acts as a **gatekeeper** / checkpoint between internal and external networks.
- Enforces the organisation's **security policy**.
- Provides a place for **monitoring and logging**; can host NAT and VPN.
- Protects internal systems from **external attacks** (scans, DoS, unauthorised access).

Limitations

- Cannot protect against attacks that **bypass** it (modem, Wi-Fi, USB).
- Cannot stop **insider** attacks.
- Cannot fully stop virus-infected files; wrong configuration creates holes.

5.3 Types of Firewall

★ Asked in BOTH papers (7M each): W2025 Q5(c)OR [packet filtering, application and circuit-level gateway] + S2026 Q5(c) [working of the three firewalls]

1) Packet-filtering firewall (network layer)

Checks **each packet separately** against a set of rules (ACL) using header information: **source/destination IP address, port numbers, protocol (TCP/UDP/ICMP)**. Packet is **allowed or dropped** according to the first matching rule. It does not look at the data inside.

- **Advantages:** fast, cheap, transparent to users.
- **Disadvantages:** does not inspect payload; weak against IP spoofing; rules are hard to write; no user authentication; limited logging.

2) Application-level gateway / proxy firewall (application layer)

Works as a **proxy**. The user connects to the gateway, the gateway checks the request (user ID, command, content) and then makes a **separate connection to the real server** on the user's behalf. A separate proxy is needed for each application (HTTP, FTP, Telnet).

- **Advantages:** most secure; inspects application data; good logging; hides internal network.
- **Disadvantages:** slower (extra processing and two connections); one proxy per application.

3) Circuit-level gateway (transport layer)

Does **not inspect the data**. It sets up **two TCP connections**: one between itself and the inside user, and another between itself and the outside host. Once the connection is allowed (after checking handshake), it simply **relays the TCP segments** from one connection to the other. Example: SOCKS.

- **Advantages:** faster than application gateway; hides internal network.
- **Disadvantages:** no content filtering - once a circuit is allowed, anything can pass.

Point	Packet filter	Application gateway	Circuit-level gateway
OSI layer	Network	Application	Transport (session)
Checks	IP, port, protocol of each packet	Full application data and user	TCP connection set-up
Speed	Fastest	Slowest	Medium
Security	Lowest	Highest	Medium

Last-minute revision sheet - Unit 5

- Intruders: Masquerader (outsider), Misfeasor (insider misuse), Clandestine user (takes supervisory control).
- IDS approaches: misuse (signatures, known attacks) vs anomaly (normal profile, unknown attacks).
- IDS parts: sensor (collect), analyzer (decide), user interface (view/control).
- Firewall goals: all traffic passes through it; only authorised traffic allowed; firewall itself immune to attack.
- Types: packet filtering (network layer), application-level gateway/proxy (application layer), circuit-level gateway (transport layer).